

CYBER SECURE SOLUTIONS

Évaluation de la posture de sécurité cloud

Type: checklist_securite_cloud

Date: 3/30/2025

Référence: La cybersécurité dans le cloud

Destinataire: Audrey

****Document Technique****

****Checklist Sécurité Cloud****

****Scénario: Évaluation de la Posture de Sécurité Cloud****

****Contact: Yousra SAIDANI****

****Destinataire: Audrey****

Objectif du Document

Ce document vise à fournir une liste de contrôle détaillée pour l'évaluation de la posture de sécurité dans un environnement cloud. Il est conçu pour un niveau expert et destiné à identifier les éventuelles failles de sécurité, les configurations inadéquates ou les zones d'amélioration dans un environnement cloud.

Contexte du Scénario

Audrey, en tant qu'experte en cybersécurité, est chargée d'évaluer la posture de sécurité d'un environnement cloud pour une organisation ayant migré une partie critique de ses infrastructures vers une solution cloud public. L'environnement inclut des services SaaS, PaaS, et IaaS, avec un usage intensif des API et des conteneurs. Un audit préalable a révélé des problèmes potentiels dans les configurations réseau et dans la gestion des identités et des accès.

Checklist Sécurité Cloud

1. ****Gestion des Accès et des Identités****

- Vérifiez l'utilisation des principes de moindre privilège pour tous les comptes utilisateurs et applications.
- Identifiez les comptes disposant de droits administratifs globaux et vérifiez la justification des privilèges.
- Examinez les configurations des rôles et des politiques IAM (Identity Access Management).
- Confirmez l'activation de l'authentification multi-facteurs (MFA) pour tous les accès sensibles.
- Analysez la rotation des clés d'accès et la gestion des certificats.

2. ****Configuration Réseau et Pare-feu****

- Vérifiez les règles de sécurité des groupes réseau (Security Groups) pour détecter les ouvertures inutiles.
- Examinez les configurations des pare-feu cloud et les éventuelles règles implicites.
- Identifiez les connexions non sécurisées (exemple : HTTP au lieu de HTTPS) et les points d'entrée

exposés.

- Évaluez l'utilisation de solutions de surveillance réseau (IDS/IPS) dans l'environnement cloud.

3. **Protocole de Sécurité des Données**

- Vérifiez les configurations de chiffrement des données au repos et en transit.
- Analysez la gestion des clés de chiffrement (KMS – Key Management Service) et leur stockage.
- Identifiez les buckets de stockage public et vérifiez leur configuration.
- Confirmez que les sauvegardes sont sécurisées et stockées dans un environnement isolé.

4. **Sécurisation des API et des Interfaces**

- Examinez les journaux d'accès des API pour détecter des anomalies ou des tentatives non autorisées.
- Vérifiez si les API exposées sont correctement sécurisées avec des jetons (OAuth, JWT).
- Confirmez que les restrictions d'origine (CORS) sont en place pour les appels API sensibles.
- Évaluez la documentation et la mise à jour des API pour identifier tout endpoint obsolète.

5. **Gestion des Conteneurs et Orchestration**

- Examinez les configurations par défaut des conteneurs et identifiez celles qui pourraient exposer l'environnement.
- Vérifiez que les images conteneurs utilisées proviennent de sources vérifiées et sont régulièrement mises à jour.
- Évaluez les politiques de sécurité au niveau de l'orchestrateur (ex. : Kubernetes RBAC).
- Confirmez que les secrets utilisés par les conteneurs sont sécurisés et non exposés dans les configurations.

6. **Surveillance et Journalisation**

- Vérifiez que tous les logs importants (IAM, réseau, API) sont activés et envoyés vers une solution SIEM centralisée.
- Identifiez les lacunes dans les alertes de sécurité en place (exemple : absence de notifications en temps réel pour les activités suspectes).
- Évaluez les contrôles périodiques des logs pour la détection proactive des menaces.

7. **Conformité et Audit**

- Assurez-vous que l'environnement cloud respecte les normes de conformité applicables (GDPR, SOC 2, ISO 27001, etc.).
- Vérifiez si des audits réguliers sont réalisés pour garantir la cohérence des configurations.
- Examinez la documentation et les politiques internes liées à la sécurité cloud.

Notes Importantes

- L'évaluation doit inclure une analyse des configurations spécifiques au fournisseur cloud (AWS, Azure, Google Cloud, etc.).
- Les résultats doivent être structurés autour des priorités de l'entreprise, en prenant en compte les applications critiques.
- L'absence de journalisation ou de mécanisme de réponse aux incidents peut constituer un risque majeur.

Fin du document

